THE HANDOVER / CASE FILE

FilsPay

CONFIDENTIAL

Evidence

CASE NO. 000

ITEM 01

COLLECTED 29.10.26

SECURITY & CODE AUDIT

ONBOARDING BRIEFING · CONFIDENTIAL

> **Your job:** Check FilsPay, a payment app made for Bahrain. It signs up shops, takes card payments, and pays the shops their money. Everything is in Bahraini Dinar (BD). 1 BD = 1000 fils.

WHAT YOU NEED TO DO

01
AUDIT
Find security holes, money bugs and anything that breaks.

02
FIX
Fix each bug with the smallest change that works.

03
EXPLAIN
For each bug, write a short note: what's wrong, why, and what it breaks.

04
BUILD
Finish the missing feature and host it on Dilmune Cloud. See the back.

THE REPO

`apps/api/`	TypeScript/Fastify API (auth, payments, webhooks, admin)
`apps/settlement/`	Go daemon (batch close, scheme export, splits, payouts)
`apps/reporting/`	TypeScript consumer (outbox events to rollups)
`apps/web/`	React hosted checkout
`apps/admin/`	React admin console
`packages/money/`	Shared integer-fils arithmetic
`packages/events/`	Outbox event types
`db/migrations/`	Postgres schema (numbered 0001 to 0072)
`scripts/`	One-off operational scripts
`ops/`	Docker compose, env files
`docs/`	Architecture, ADRs, runbook, handover notes

WHERE TO START

- Start with `docs/ARCHITECTURE.md` and `docs/HANDOVER.md`
- Read every ADR in `docs/adr/`. They are the rules the code should follow
- Money rule: **whole fils only, never decimals** (ADR-0001)
- Settlement closes every day at midnight, Bahrain time (UTC+3)
- Run `docker compose up` in `ops/` to start everything on your laptop

`SCORING` Bigger bugs get more points, and so do clear explanations. Explaining why a bug happens scores more than just spotting it. A small fix that works scores more than a big rewrite.

FilsPay

ASSIGNED TO YOU

FP-300 | Feature | Priority: High | Status: To do

UNFINISHED

FINISH THE MISSING FEATURE

REQUESTED BY PRODUCT · NEVER SHIPPED

> The last developer started a feature but never finished it. Find out what it is, build it so it works from start to end, and host the app on Dilmune Cloud.

DONE WHEN

- [ ] The feature **works from start to end**, through the API
- [ ] The **money is right** in the ledger, down to the fils
- [ ] **Fees and payouts** come out right
- [ ] The shop gets the **right webhook**
- [ ] It shows up right in the **timeline**, the **reports** and **reconciliation**
- [ ] The app is **live on Dilmune Cloud**, our hosting provider

"looks easy. it isn't. it touches everything."

FilsPay

ASSIGNED TO YOU

Evidence

CASE NO. 000
ITEM 03
COLLECTED 29.10.26

SUPPORT TICKET EXCERPTS & INCIDENT NOTES

Redacted extract. Internal reference only.

PREPARED BY [redacted] SOURCE [redacted]

FP-187

Payment link paid after expiry

A buyer says the link showed "expired", but the payment still went through. The checkout page sends something that the server shouldn't trust. Engineering flagged this months ago.

FP-201

REOPENED

Duplicate notes on acquirer callbacks

The bank sent the same callback twice and we saved two identical notes on one payment. The 1.9.0 postmortem says this was fixed. It wasn't.

FP-203

Balance cache wrong after admin action

An admin clicked "Recalculate cached balances" and a merchant's balance dropped from 135K to 7K. The CLI tool gives the right number. The two read from different places.

FP-209

Concurrent refund: double money out

Two refund requests came in at the same time. Both went through, and we lost money. Normal payments don't have this problem. So why do refunds?

FP-240

Webhook signatures rejected by merchants

Some merchants can't verify our webhook signatures. The part that signs the message and the part that sends it don't agree on what it looks like. Also, someone said the incoming signature check has its own problems.

INCIDENT 2026-05-14

Payment link charged twice

A slow payment let a second buyer use the same link before the first one finished. Both were charged. The code comments say "this IS reachable."

INCIDENT 2026-08-21

Duplicate payout notifications

Shops got two "your payout is on the way" messages for the same payout. Two processes checked at the same time, and both thought they were first.

things that feel wrong but nobody's filed tickets for:

- *can you refund more than what was actually charged?*
- *the settlement splits are always a few fils short*
- *some admin actions don't seem to have the right role checks*
- *there's a key rotation flow that doesn't do what you'd expect*
- *the daily close timing doesn't match what the docs say*
- *one of the reporting queries is suspiciously slow*
- *what happens to test merchants when certain admin tools run?*
- *the OTP implementation changed at some point. is it still safe?*
- *has anyone tried uploading a really large export?*

FilsPay

Evidence
CASE NO. 000
ITEM 02
COLLECTED 29.10.26

FINANCE & OPS WEEKLY

Circulated 2026-09-20. Do not distribute.

FROM Fatima H. (Finance)

RE Open items from the Sep 17 reconciliation review

The numbers still don't match. I listed everything below, but nobody has time to check all of it before the audit. Leaving it for whoever picks this up.

- ☐ The **scheme statement** total is always a few fils higher than ours. It's always *over*, never under. I checked three months and it's the same every time. Something is rounding, but I can't find where.
- ☐ Related: the **March sweep script** was meant to fix the leftover gap for Q1. It did, but someone ran it twice on staging and the gap doubled. Nobody knows if it ran more than once on production. The log file only has one timestamp. Is it safe to run again? *I wouldn't.*
- ☐ **Split payouts** for Delta Marketplace: the three child payouts don't add up to the parent's total. It's small, a few tens of fils each batch, but it happens every batch since launch. Where do the missing fils go? I can't find them anywhere in the ledger. !!
- ☐ The **"Recalculate cached balances" button** in admin: I pressed it last Thursday and Alpha Retail's balance went from 135K to 7K. Yousif had to run the CLI rebuild to fix it. Why do the button and the CLI give different numbers?
- ☐ **MDR recalculation** changed batches that were already paid out. Those should never change. The settlement team says it only touches open batches, but I'm seeing changes on closed ones too.
- ☐ Support says the **fee shown in the merchant dashboard** isn't what we actually charge. It shows 245bps, but payments go through at 225bps. The two fee tables have different dates, and one was a backfill fix.
- ☐ The **CSV import** for manual changes: I uploaded 4.755 BD and the ledger shows 4.750. I uploaded 4.75 BD and it shows 0.475. That's ten times less. Something is wrong with how it reads BD amounts. 10x??

Other things people said in the group chat. I haven't checked these:

> "The daily close is running at 3am local, not midnight"
> "Lifetime payout estimate drifts for high-volume merchants"
> "Test merchants keep showing up in the real settlement run"
> "Login works without entering the OTP code?"
> "I cancelled merchant B's payment link from merchant A's dashboard"

I'm on leave next week. Good luck.

F.